



DATABASE SECURITY



ACCESS CONTROL

Lê Thị Minh Châu
Faculty Of Information Technology
HCMC University Of Technology And Education

Outline



2

- Three Basic Concepts
 - DAC
 - MAC
 - RBAC
 - Attribute Based Access Control
- Conclusion



Three Basic Concepts

3

- **Authentication:** a mechanism that determines whether a user is who he or she claims to be.
- **Authorization:** the granting of a right or privilege, which enables a subject to legitimately have access to a system or a system's objects.
- **Access Control:** a security mechanism (of a DBMS) for restricting access to a system's objects (the database) as a whole.

Discretionary Access Control (DAC)



4

- Widely used in modern operating systems
- In most implementations it has the notion of owner of an object
- The owner controls other users' accesses to the object
- Allows access rights to be propagated to other subjects

Discretionary Access Control (DAC)



5

- **DAC:** granting access to the data on the basis of users' identity and of rules that specify the types of access each user is allowed for each object in the system.
- Identification & authentication: 1st procedure
 - ▣ Identification: a user claims who s/he is
 - ▣ Authentication: establishing the validity of this claim
 - something the user *knows* (e.g., a password, PIN)
 - something the user *possesses* (e.g., an ATM card)
 - something the user *is* (e.g., a voice pattern, a fingerprint)

Discretionary Access Control (DAC)



6

- The typical method of enforcing DAC in a database system is based on the granting and revoking privileges.
- SQL standard supports DAC through the GRANT and REVOKE commands: The GRANT command gives privileges to users, and the REVOKE command takes away privileges.



Problems with DAC in OS

7

- DAC cannot protect against
 - ▣ Trojan horse
 - ▣ Malware
 - ▣ Software bugs
 - ▣ Malicious local users

- It cannot control information flow

DAC & Information Flow Controls



8

- Inherent weakness of DAC: Unrestricted DAC allows information from an object which can be read by a subject to be written to any other object
 - ▣ Bob is denied access to file A, so he asks cohort Alice to copy A to B that he can access
- Suppose our users are trusted not to do this deliberately. It is still possible for Trojan Horses to copy information from one object to another.

Trojan Horse Example



9

User Alice

r: Alice; w:Alice

File A

User Bob

r: Bob; w:Bob

File B

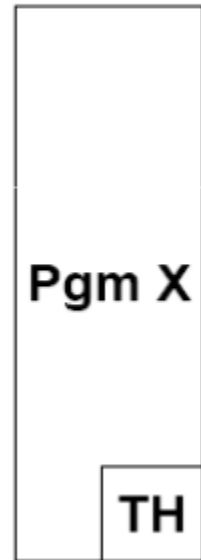
User Bob cannot read the file A!

Trojan Horse Example



10

User Alice

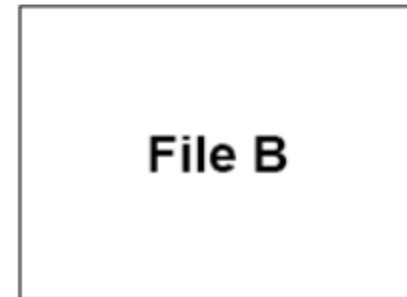


User Bob

r: Alice; w:Alice



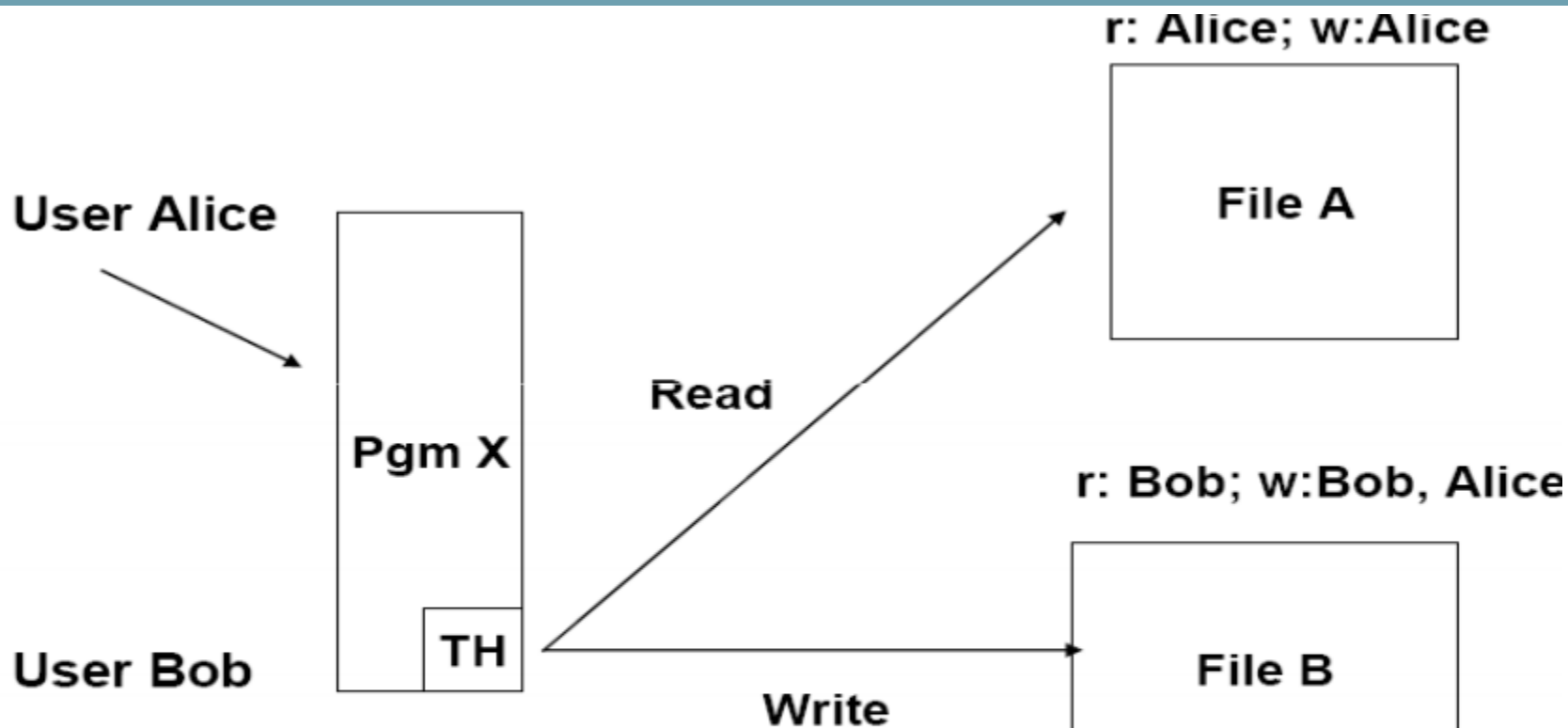
r: Bob; w:Bob, Alice





Trojan Horse Example

11

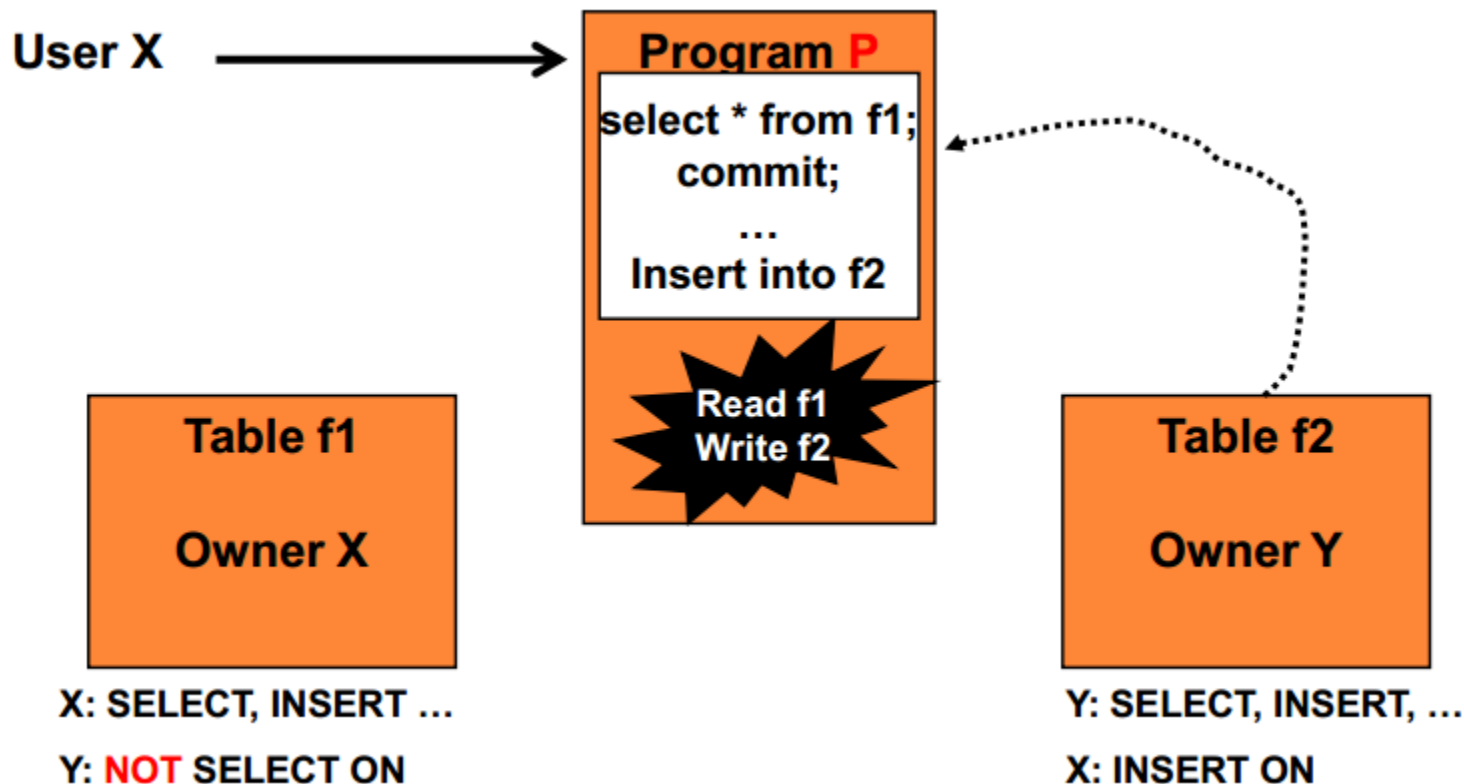


User Bob can read contents of file A
copied to file B



Trojan Horse Example

12



Mandatory Access Control (MAC)



13

- Mandatory access control (*MAC*) restricts the access of subjects to objects based on a system-wide policy
- The system security policy (as set by the administrator) entirely determines the access rights granted
 - ▣ denying users full control over the access to resources that they create.



The Need for MAC

14

- Host compromise by network-based attacks is the root cause of many serious security problems
 - ▣ Worm, Botnet, DDoS, Phishing, Spamming

- Why hosts can be easily compromised
 - ▣ Programs contain exploitable bugs
 - ▣ The discretionary access control mechanism in the operating systems was not designed by taking into account buggy software

Mandatory Access Control (MAC)



15

- ❑ MAC specifies the access that subjects have to objects based on subjects and objects classification
- ❑ This type of security has also been referred to as multilevel security
- ❑ Database systems that satisfy multilevel security properties are called multilevel secure database management systems (MLS/DBMSs)
- ❑ Many of the MLS/DBMSs have been designed based on the Bell and LaPadula (BLP) model



Multilevel relation

16

- A multilevel relation will appear to contain different data to subjects (users) with different security levels

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

A Characterization of the Difference between DAC and MAC



17

- Discretionary Access Control Models (DAC)
 - Definition [Bishop p.53] If an individual user can set an access control mechanism to allow or deny access to an object, that mechanism is a *discretionary access control (DAC)*, also called an *identity-based access control (IBAC)*.
- Mandatory Access Control Models (MAC)
 - Definition [Bishop p.53] When a system mechanism controls access to an object and an individual user cannot alter that access, the control is a *mandatory access control (MAC)* [, occasionally called a *rule-based access control*.]

Bell and LaPadula (BLP) Model



18

Elements of the model:

- *objects* - passive entities containing information to be protected
- *subjects*: active entities requiring accesses to objects (*users, processes*)
- *access modes*: types of operations performed by subjects on objects
 - read: reading operation
 - append: modification operation
 - write: both reading and modification

BLP Model



19

- Subjects are assigned **clearance** levels and they can operate at a level up to and including their clearance levels
- Objects are assigned **sensitivity** levels
- The clearance levels as well as the sensitivity levels are called **access classes**

BLP Model - Access Classes



20

- An access class consists of two components
a **security level** a **category set**
- The security level is an element from a totally ordered set - example
 $\{\text{Top Secret (TS), Secret (S), Confidential (C), Unclassified (U)}\}$
where $TS > S > C > U$
- The category set is a set of elements,
dependent from the application area in which
data are to be used - example
 $\{\text{Army, Navy, Air Force, Nuclear}\}$

BLP Model - Access Classes



21

- Access class $c_i = (L_i, SC_i)$ **dominates** access class $c_k = (L_k, SC_k)$, denoted as $c_i \geq c_k$, if both the following conditions hold:
 - ▣ $L_i \geq L_k$ The security level of c_i is greater or equal to the security level of c_k
 - ▣ $SC_i \supseteq SC_k$ The category set of c_i includes the category set of c_k

BLP Model - Access Classes



22

- If $L_i > L_k$ and $SC_i \supset SC_k$, we say that c_i **strictly dominates** c_k
- c_i and c_k are said to be **incomparable** (denoted as $c_i < > c_k$) if
neither $c_i \geq c_k$ nor $c_k \geq c_i$ holds



BLP Model - Examples

23

□ Access classes

□ $c_1 = (TS, \{\text{Nuclear}, \text{Army}\})$

□ $c_2 = (TS, \{\text{Nuclear}\})$

□ $c_3 = (C, \{\text{Army}\})$

□ $c_1 \geq c_2$

□ $c_1 > c_3$ ($TS > C$ and $\{\text{Army}\} \subset \{\text{Nuclear}, \text{Army}\}$)

□ $c_2 < > c_3$



BLP Model - Axioms

24

- The state of the system is described by the pair (A, L) , where:
 - ▣ A is the *set of current accesses*: triples of the form (s, o, m) denoting that subject s is exercising access m on object o - example $(\text{Bob}, o_1, \text{read})$
 - ▣ L is the *level function*: it associates each element in the system with its access class

Let O be the set of objects, S the set of subjects, and C the set of access classes

$$L : O \cup S \rightarrow C$$



BLP Model - Axioms

25

□ Simple security property (*no-read-up*)

a given state (A, L) satisfies the simple security property if for each element $a = (s, o, m) \in A$ one of the following condition holds

1. $m = \text{append}$
2. $(m = \text{read or } m = \text{write})$ and $L(s) \geq L(o)$

□ Example: a subject with access class $(C, \{\text{Army}\})$ is not allowed to read objects with access classes $(C, \{\text{Navy, Air Force}\})$ or $(U, \{\text{Air Force}\})$

BLP Model - Axioms



26

- The simple security property prevents subjects from reading data with access classes dominating or incomparable with respect with the subject access class
- It therefore ensures that subjects have access only to information for which they have the necessary access class



BLP Model - Axioms

27

□ Star (*) property (*no-write-down*)

a given state (A, L) satisfies the *-property if for each element $a = (s, o, m) \in A$ one of the following condition holds

1. $m = \text{read}$
2. $m = \text{append}$ and $L(o) \geq L(s)$
3. $m = \text{write}$ and $L(o) = L(s)$

□ Example: a subject with access class

$(C, \{\text{Army}, \text{Nuclear}\})$ is not allowed to append data into objects with access class $(U, \{\text{Army}, \text{Nuclear}\})$

BLP Model - Axioms



28

- The *-property has been defined to prevent information flow into objects with lower-level access classes or incomparable classes
- For a system to be secure both properties must be verified by any system state

Summary of BLP Model



29

- Typical **security classes** are top secret (TS), secret (S), confidential (C), and unclassified (U): $TS \geq S \geq C \geq U$
- Two restrictions are enforced on data access based on the subject/object classifications:
 - ▣ A subject S is not allowed read access to an object O unless $\text{class}(S) \geq \text{class}(O)$. This is known as the **simple security property**.
 - ▣ A subject S is not allowed to write an object O unless $\text{class}(S) \leq \text{class}(O)$. This known as the **star property** (or $*$ property).



Multilevel relation

30

SELECT * FROM EMPLOYEE

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

➤ A user with security level S

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S



Multilevel relation

SELECT * FROM EMPLOYEE

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

➤ A user with security level C

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	null	C	C
Brown	C	null	C	Good	C	C



Multilevel relation

32

SELECT * FROM EMPLOYEE

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

➤ A user with security level U

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	null	U	null	U	U



Multilevel relation

33

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Brown	C	80000	S	Good	C	S

EMPLOYEE (security level C)

Name		Salary		JobPerformance		TC
Smith	U	40000	C	null	C	C
Brown	C	null	C	Good	C	C

- A user with *security level C* tries to update the value of JobPerformance of Smith to 'Excellent':

UPDATE EMPLOYEE

SET JobPerformance = 'Excellent'

WHERE Name = 'Smith';



Multilevel relation

34

EMPLOYEE

Name		Salary		JobPerformance		TC
Smith	U	40000	C	Fair	S	S
Smith	U	40000	C	Excellent	C	C
Brown	C	80000	S	Good	C	S

Pros and Cons of MAC



35

□ Pros:

- Provide a high degree of protection – in a way of preventing any illegal flow of information.
- Suitable for military types of applications.

□ Cons:

- Not easy to apply: require a strict classification of subjects and objects into security levels.
- Applicable for very few environments.

Role-Based Access Control – RBAC



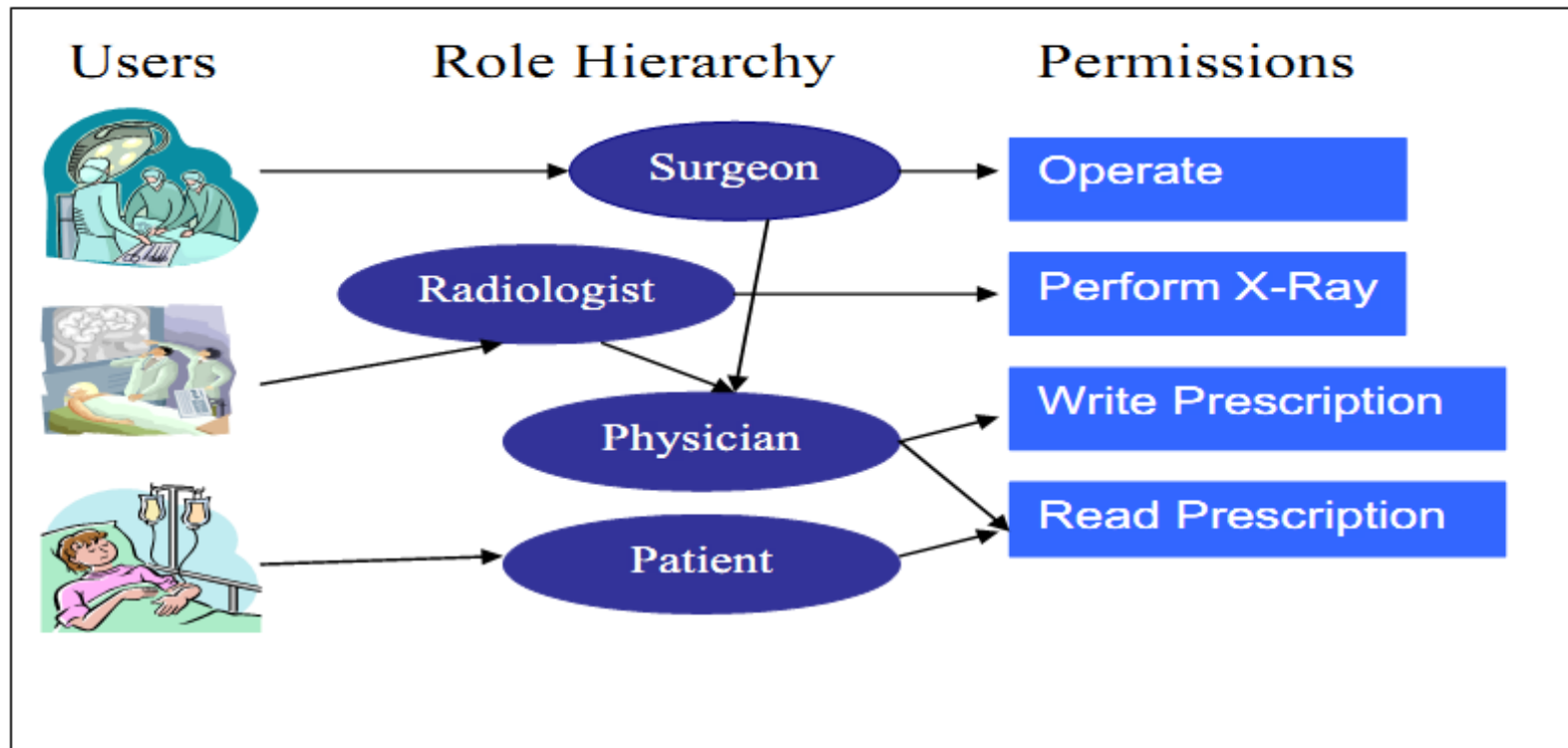
36

- RBAC emerged rapidly in the 1990s as a proven technology for managing and enforcing security in large-scale enterprise systems.
- Its basic notion is that permissions are associated with roles, and users are assigned to appropriate roles.
- Roles can be created using the CREATE ROLE and DESTROY ROLE commands. Similarly to DAC, the GRANT and REVOKE commands can then be used to assign and revoke privileges from roles.

Role-Based Access Control – RBAC



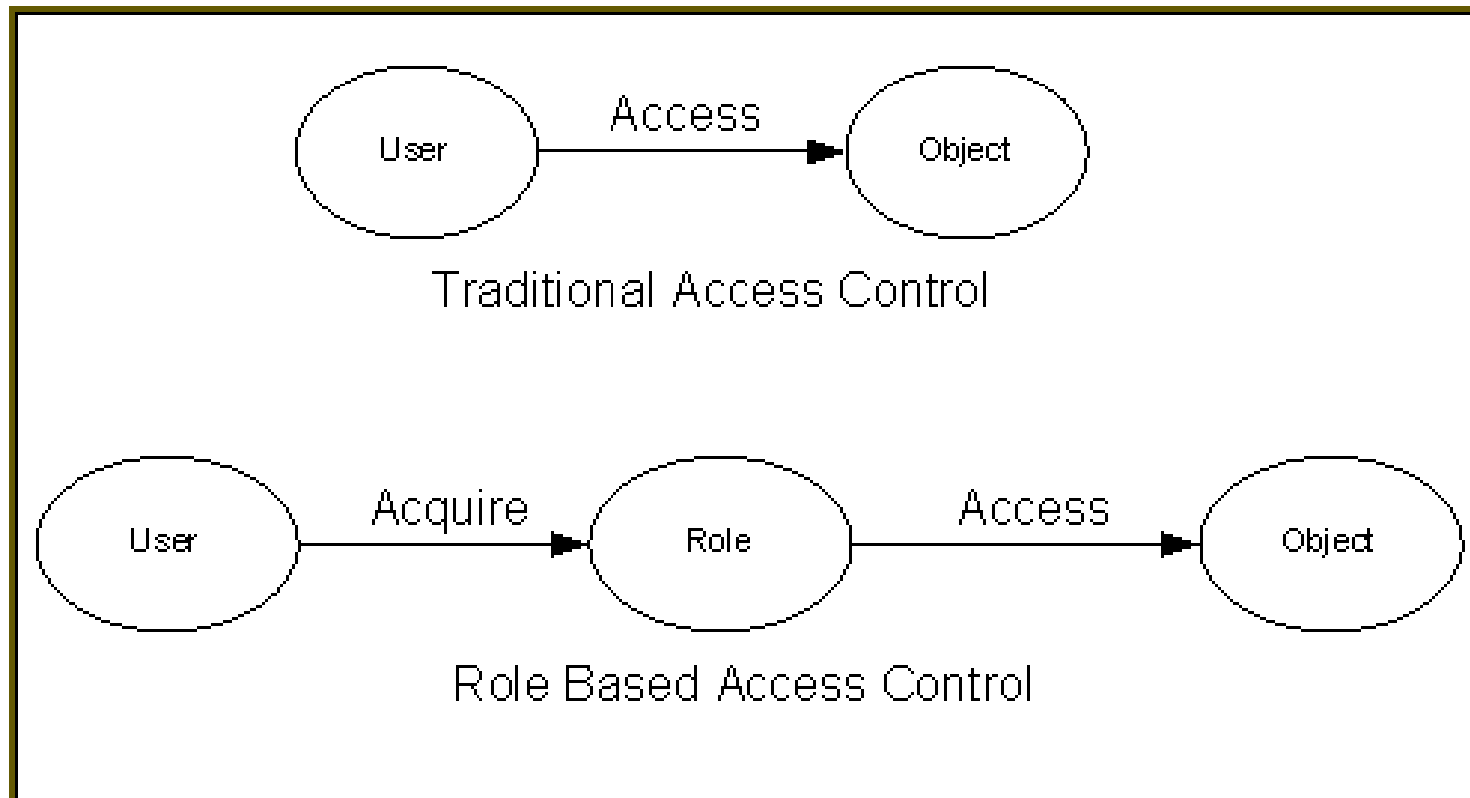
37



Role-Based Access Control – RBAC



38

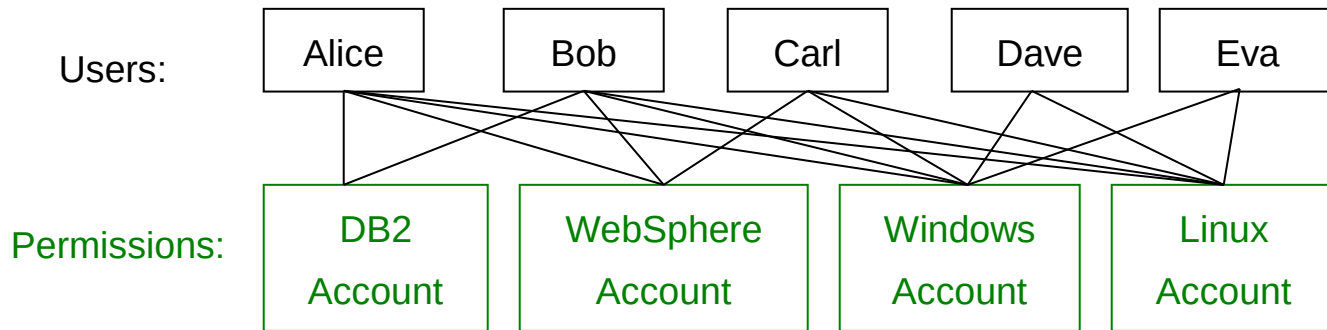


Role-Based Access Control – RBAC

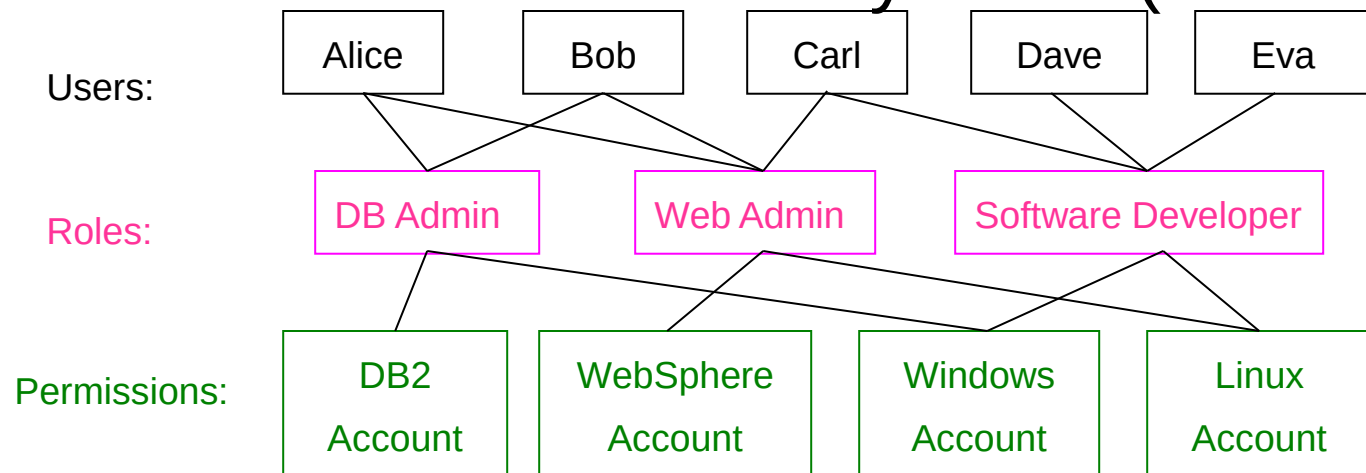


39

□ Non-role-based systems



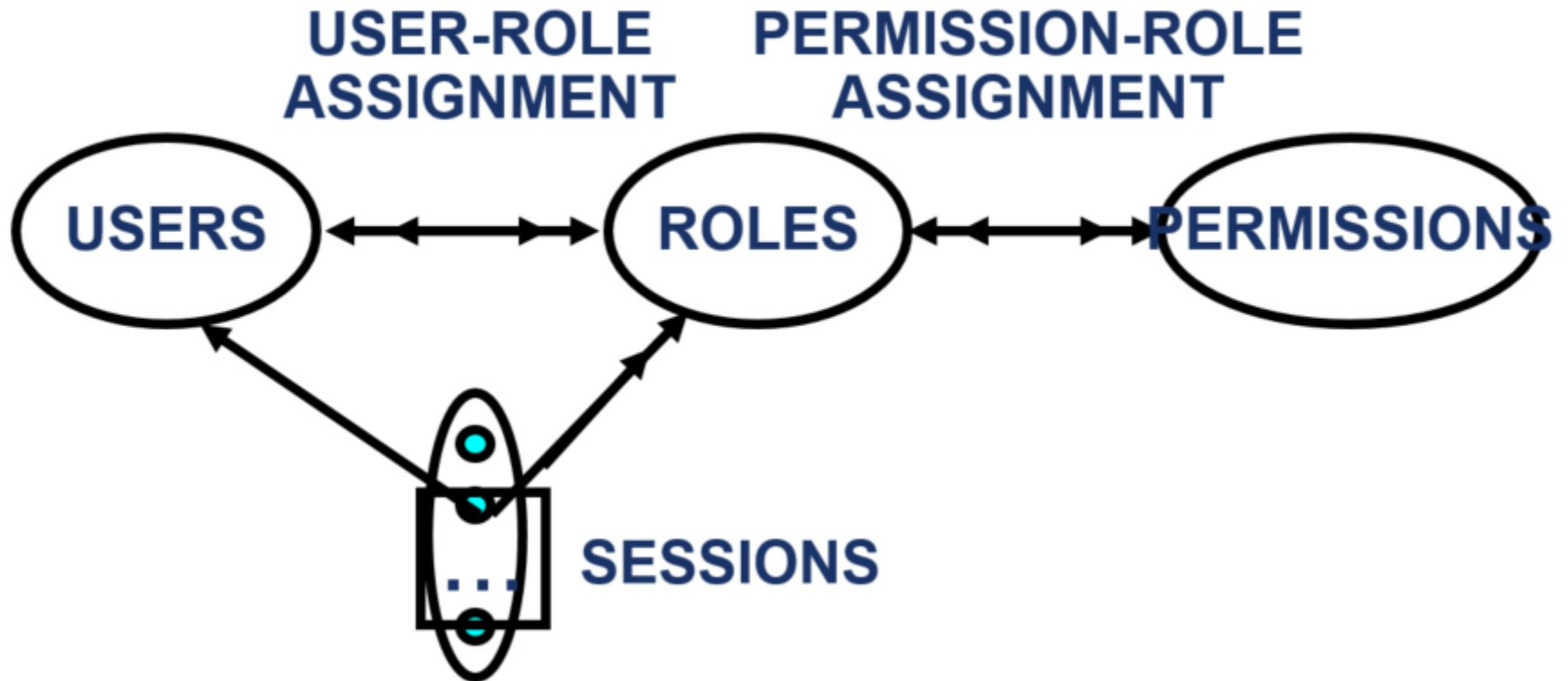
□ Role-Based Access Control Systems (RBAC)



Core RBAC



40



Pros and Cons of RBAC



41

□ Pros:

- Simple, efficient model.
- Suitable for most of the applications in practice.
- Simple to manage permissions, managing permissions on each group instead of on each user → reduce the effort, time and risk of confusion.

Pros and Cons of RBAC



42

□ Cons:

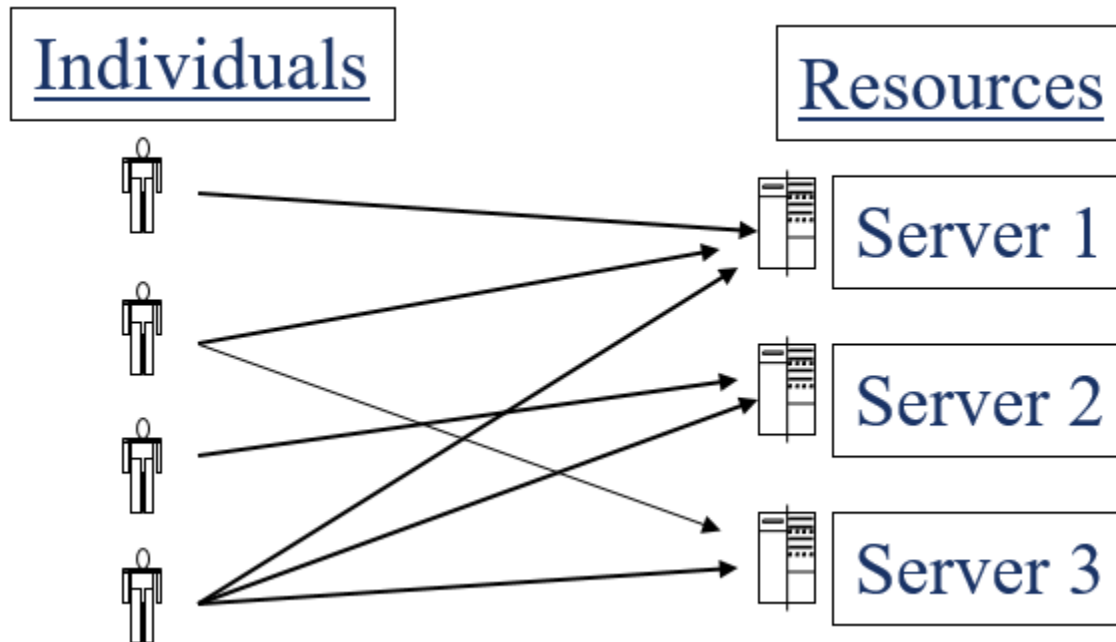
- Not suitable for some resources to be protected that is not known in advance.
- Not suitable for applications where a user can have many roles in conflict.

Conclusion



43

□ DAC



Application Access List

<u>Name</u>	<u>Access</u>
Tom	Yes
John	No
Cindy	Yes

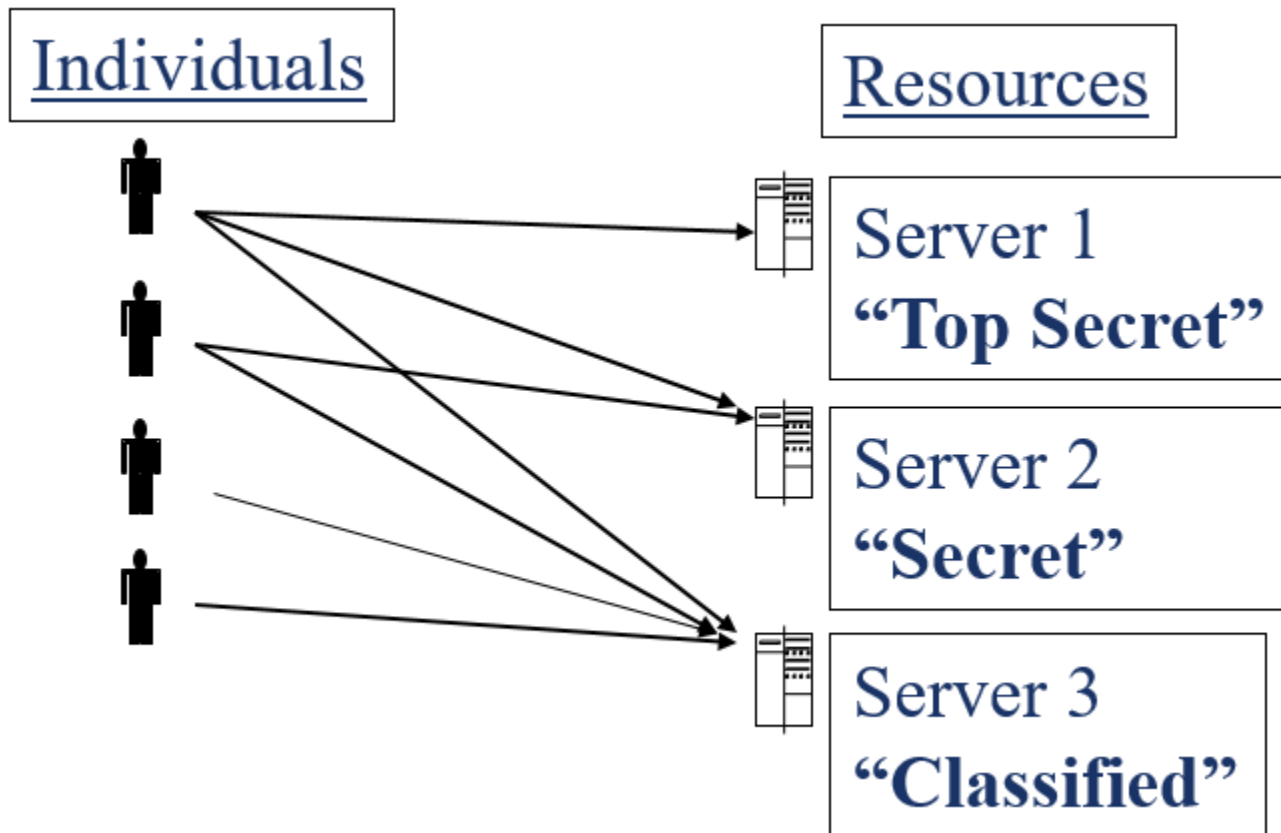


Conclusion



44

□ MAC

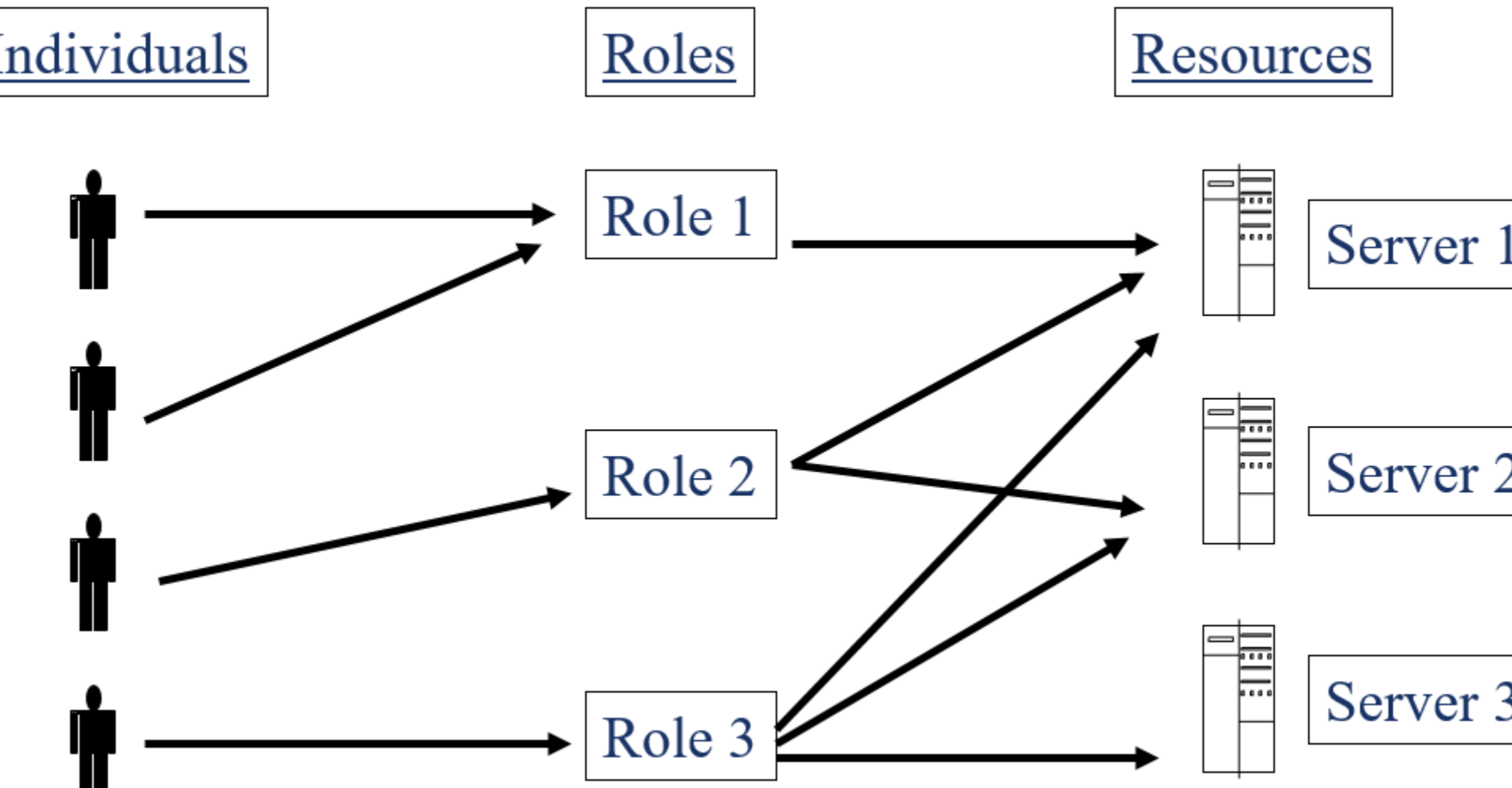


Conclusion



45

□ RBAC



Q&A



46

